



RAPPORT D'AUDIT DE CYBERSÉCURITÉ

Bordeaux Football Club

Audit Blue Team & Renforcement de la posture de cybersécurité

Client :	Bordeaux Football Club
Auditeur :	Marc DUVERGER
Date :	Avril 2026
Référence :	AUD-BFC-2026-001

DOCUMENT CONFIDENTIEL - DIFFUSION RESTREINTE

Sommaire

1. Introduction	3
1.1 Contexte de la mission	3
1.1 Objectifs de l'audit	3
1.2 Périmètre de l'audit	4
1.3 Schéma de l'infrastructure	4
1.4 Dashboard OPNsense	5
2.1 Approche Blue Team	6
2.2 Référentiels et normes appliqués	6
2.3 Outils utilisés	7
2.4 Planning de l'audit	7
3. État des lieux et analyse du niveau de sécurité	8
3.1 Inventaire des actifs	8
3.2 Points de contrôle et vulnérabilités identifiées	9
4. Élaboration et mise en œuvre de la politique de sécurité	12
4.2 Renforcement de l'authentification	12
4.3 Architecture Zero Trust	13
4.4 Sécurisation de la DMZ	15
4.5 Règles de pare-feu OPNsense	16
5. Détection et traitement des incidents de sécurité	18
5.1 Architecture de supervision déployée	18
5.2 Déploiement de Wazuh	19
5.3 Simulation d'incident : attaque brute-force SSH	22
5.4 Procédure de réponse aux incidents	28
6. Sensibilisation des utilisateurs	30
6.1 Campagnes de phishing simulées	30
7. Veille en cybersécurité	31
7.1 Sources de veille	31
7.2 Processus de veille	31
8. Synthèse des résultats	32
9. Conclusion	33
Annexes	34
Annexe A : Glossaire	34
Annexe B : Environnement de lab (VMware)	34
Annexe C : Références	34
Annexe D : Analyse détaillée des CVE critiques	35

1. Introduction

1.1 Contexte de la mission

Le Bordeaux Football Club (BFC) est un club de football professionnel, basé à Bordeaux, employant environ 250 collaborateurs (staff sportif, administratif, médical et communication). Le club gère des données sensibles : contrats de joueurs, données médicales, informations financières liées aux transferts et billetterie.

En janvier 2026, le BFC a été victime d'une tentative de fraude au président (attaque par ingénierie sociale) qui a failli aboutir au détournement de 42 millions d'euros destinés à un transfert de joueur. L'attaquant avait compromis la messagerie du directeur financier via un phishing ciblé, puis usuré son identité pour ordonner un virement frauduleux. Le virement a été bloqué in extremis par la banque.

Suite à cet incident majeur, la direction du BFC a décidé de renforcer en urgence son infrastructure informatique. Une première mise en place a été réalisée par l'équipe IT interne avec un réseau segmenté en VLANs, un serveur en DMZ, un serveur d'administration sous Active Directory et des postes clients. Cependant, cette infrastructure nécessite un audit approfondi et un renforcement sécuritaire complet.

C'est dans ce contexte que le BFC a fait appel à nos services pour réaliser un audit de cybersécurité Blue Team et implémenter les mesures de sécurisation nécessaires.

1.1 Objectifs de l'audit

- **Évaluer** le niveau de sécurité actuel de l'infrastructure du BFC
- **Identifier** les vulnérabilités et les risques associés
- **Proposer et implémenter** des mesures correctives conformes aux bonnes pratiques (ANSSI, Zero Trust)
- **Mettre en place** un système de détection et de réponse aux incidents (Wazuh, Suricata, OPNsense)
- **Sensibiliser** les équipes aux risques cyber et aux bonnes pratiques
- **Documenter** l'ensemble des procédures et politiques de sécurité

1.2 Périmètre de l'audit

L'audit couvre l'ensemble de l'infrastructure IT du BFC :

- **Réseau** : segmentation VLAN, pare-feu, règles de filtrage
- **Serveurs** : DMZ (Ubuntu Server), Active Directory (Windows Server 2022), postes clients
- **Authentification** : politique de mots de passe, MFA, gestion des comptes
- **Supervision** : mise en place SIEM (Wazuh), IDS/IPS (Suricata), pare-feu (OPNsense)
- **Organisationnel** : sensibilisation, procédures, veille cybersécurité

1.3 Schéma de l'infrastructure

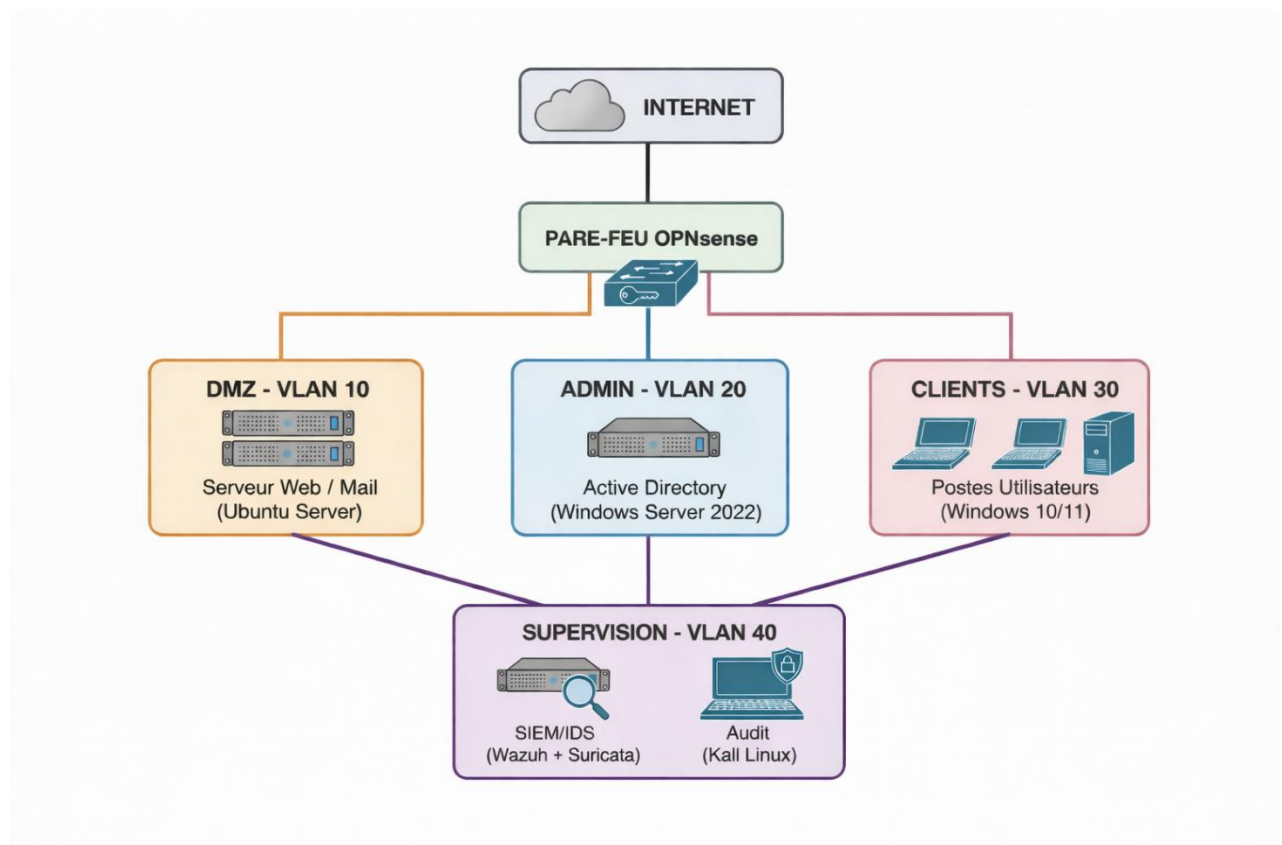


Figure 1 - Schéma de l'infrastructure réseau du BFC

VLAN	Rôle	Système	Adressage
VLAN 10 (VMnet3)	DMZ (services exposes)	Ubuntu Server 22.04	172.16.10.0/24
VLAN 20 (VMnet2)	Administration / AD	Windows Server 2022	172.16.20.0/24
VLAN 30 (VMnet4)	Postes clients	Windows 10/11	172.16.30.0/24
VLAN 40 (VMnet5)	Supervision / Audit	Kali Linux / Wazuh	172.16.40.0/24

Name	Type	External Connection	Host Connection	DHCP	Subnet Address
VMnet0	Bridged	Auto-bridging	-	-	-
VMnet2	Host-only	-	Connected	-	172.16.10.0
VMnet3	Host-only	-	Connected	-	172.16.20.0
VMnet4	Host-only	-	Connected	-	172.16.30.0
VMnet5	Host-only	-	Connected	-	172.16.40.0

Figure 2 - Configuration des réseaux virtuels VMware

```

*** OPNsense.internal: OPNsense 26.1.2_5 (amd64) ***

LAN (em1)      -> v4: 172.16.10.1/24
OPT1 (em2)     -> v4: 172.16.20.1/24
OPT2 (em3)     -> v4: 172.16.40.1/24
OPT3 (em4)     -> v4: 172.16.30.1/24
WAN (em0)      -> v4/DHCP4: 192.168.1.21/24

```

Figure 3 - Interfaces OPNsense configurées avec les IPs

1.4 Dashboard OPNsense

Interface Statistics						
Interface	Bytes In	Bytes Out	Packets In	Packets Out	Errors In	Errors Out
Collisions						
WAN	1.55 GB	1.18 GB	15 460 261	15 234 333	0	0
0						
OPT3	6.38 KB	252.00 B	38	6	0	0
0						
OPT2	5.41 MB	341.76 MB	68 650	247 212	0	0
0						
OPT1	8.05 MB	19.52 MB	26 734	37 538	0	0
0						
LAN	14.38 MB	24.04 MB	39 932	44 750	0	0
0						

Firewall					
Live Log					
Action	Time	Interface	Source	Destination	Port
	08:28	WAN	192.168.1.21	8.8.8.8	53

Figure 4 - Dashboard OPNsense : Interface Statistics et Firewall Live Log

Interface Statistics						
Interface	Bytes In	Bytes Out	Packets In	Packets Out	Errors In	Errors Out
Collisions						
WAN	572.64 KB	319.24 KB	2 637	2 026	0	0
0						
SUPERVISION	303.00 B	42.00 B	2	1	0	0
0						
LAN	442.48 KB	5.59 MB	2 870	4 908	0	0
0						
DMZ	243.00 B	42.00 B	1	1	0	0
0						
Firewall						
Live Log						
Action	Time	Interface	Source	Destination	Port	
▶	09:26	WAN	192.168.1.21	5.196.76.84	123	
▶	09:26	WAN	192.168.1.21	109.190.177.203	123	

Figure 5 - Dashboard OPNsense : statistiques des interfaces et Firewall Live Log

2. Méthodologie d'audit

2.1 Approche Blue Team

L'audit est conduit selon une approche Blue Team (défensive). Contrairement à un audit Red Team qui simule des attaques, notre démarche vise à :

- **Analyser** la configuration existante et identifier les écarts par rapport aux bonnes pratiques
- **Évaluer** les mécanismes de protection en place
- **Renforcer** les défenses et la capacité de détection
- **Mettre en place** une surveillance continue et un plan de réponse aux incidents

2.2 Référentiels et normes appliqués

Référentiel	Utilisation dans l'audit
ANSSI - Guide d'hygiène informatique	42 mesures de sécurité comme base de contrôle
ANSSI - Recommandations mots de passe	Politique de mots de passe conforme
NIST Cybersecurity Framework	Identification, Protection, Détection, Réponse, Récupération
Zero Trust (NIST SP 800-207)	Architecture de confiance zéro
MITRE ATT&CK	Matrice des tactiques et techniques d'attaque

2.3 Outils utilisés

Outil	Type	Utilisation
Wazuh	SIEM / XDR	Collecte et corrélation des logs, détection d'incidents
Suricata	IDS / IPS	Détection d'intrusions réseau en temps réel
OPNsense	Pare-feu / UTM	Filtrage réseau, VPN, proxy
Kali Linux	Audit	Tests de configuration, scans de vulnérabilités
Nmap	Scanner réseau	Découverte des services et ports ouverts
Lynis	Audit système	Audit de durcissement Linux
Hydra	Brute-force SSH	Audit de résistance des mots de passe
Purple Knight	Audit Active Directory	Évaluation sécurité Active Directory
Gophish	Phishing simulé	Campagnes de sensibilisation
Wireshark	Analyse réseau	Analyse forensique des captures PCAP
fail2ban	Protection brute-force	Blocage automatique des IP malveillantes

2.4 Planning de l'audit

Semaine	Phase	Activités	Livrable
S1	Découverte et cadrage	Réunion de lancement, inventaire des actifs	Note de cadrage
S2	Analyse et évaluation	Scans Nmap, audit des configurations, analyse des risques	Rapport de vulnérabilités
S3	Remédiations	MFA, mots de passe ANSSI, Zero Trust, durcissement DMZ	Plan de remédiation
S4	Détection & Supervision	Déploiement Wazuh, Suricata, OPNsense	Dossier de supervision
S5	Clôture	Tests de validation, sensibilisation, rapport final	Rapport d'audit final

3. État des lieux et analyse du niveau de sécurité

3.1 Inventaire des actifs

Actif	OS / Version	VLAN	Services critiques
SRV-DMZ-01	Ubuntu 24.04 LTS	VLAN 10	Apache, SSH, fail2ban
SRV-AD-01	Windows Server 2022	VLAN 20	AD DS, DNS interne, DHCP, GPO
PC-AUDIT	Kali Linux 2024	VLAN 40	Nmap, Hydra, Lynis
SRV-WAZUH	Ubuntu Desktop 24.04	VLAN 40	Wazuh Manager, Indexer, Dashboard
FW-OPNSENSE	OPNsense 26.1	Multi-VLAN	Pare-feu, routage inter-VLAN

```
PS C:\Users\Administrateur> ipconfig /all

Configuration IP de Windows

Nom de l'hôte . . . . . : SRV-AD-01
Suffixe DNS principal . . . . . : bluey.local
Type de noeud . . . . . : Hybride
Routage IP activé . . . . . : Non
Proxy WINS activé . . . . . : Non
Liste de recherche du suffixe DNS.: bluey.local

Carte Ethernet Ethernet0 :

Suffixe DNS propre à la connexion. . . :
Description. . . . . : Intel(R) 82574L Gigabit Network Connection
Adresse physique . . . . . : 00-0C-29-F6-2A-00
DHCP activé. . . . . : Non
Configuration automatique activée. . . : Oui
Adresse IPv6 de liaison locale. . . . : fe80::f850:e088:19f5:d603%10(préfééré)
Adresse IPv4. . . . . : 172.16.20.10(préfééré)
Masque de sous-réseau. . . . . : 255.255.255.0
Passerelle par défaut. . . . . : 172.16.20.1
IAID DHCPv6 . . . . . : 100666409
DUID de client DHCPv6. . . . . : 00-01-00-01-31-58-23-4D-00-0C-29-F6-2A-00
Serveurs DNS. . . . . : ::1
127.0.0.1
NetBIOS sur Tcpip. . . . . : Activé
```

Figure 7 - Configuration IP du serveur Active Directory (SRV-AD-01)

```
marc@marc-VMware-Virtual-Platform:~$ ping 172.16.10.1
PING 172.16.10.1 (172.16.10.1) 56(84) bytes of data:
64 bytes from 172.16.10.1: icmp_seq=1 ttl=64 time=3.25 ms
64 bytes from 172.16.10.1: icmp_seq=2 ttl=64 time=0.625 ms
64 bytes from 172.16.10.1: icmp_seq=3 ttl=64 time=1.13 ms
64 bytes from 172.16.10.1: icmp_seq=4 ttl=64 time=0.446 ms
64 bytes from 172.16.10.1: icmp_seq=5 ttl=64 time=0.575 ms
64 bytes from 172.16.10.1: icmp_seq=6 ttl=64 time=1.02 ms
```

Figure 9 - Test de connectivité DMZ vers OPNsense

```
(kali@kali)-[~]
$ ip addr show
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:c2:6c:ac brd ff:ff:ff:ff:ff:ff
    inet 172.16.40.10/24 brd 172.16.40.255 scope global eth0
        valid_lft forever preferred_lft forever
```

Figure 10 - Configuration IP de la machine d'audit (Kali Linux)

3.2 Points de contrôle et vulnérabilités identifiées

3.2.1 Scan réseau avec Nmap

Des scans Nmap ont été réalisés depuis la machine d'audit (Kali Linux) sur chaque serveur afin d'identifier les services exposés et les ports ouverts.

```
(kali@kali)-[~]
$ sudo nmap -sV -sC -Pn 172.16.20.10
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-06 06:15 -0400
Nmap scan report for 172.16.20.10
Host is up (0.00041s latency).
Not shown: 986 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
53/tcp    open  domain         Simple DNS Plus
88/tcp    open  kerberos-sec   Microsoft Windows Kerberos (server time: 2026-04-06 10:15:26Z)
135/tcp   open  msrpc          Microsoft Windows RPC
139/tcp   open  netbios-ssn    Microsoft Windows netbios-ssn
389/tcp   open  ldap           Microsoft Windows Active Directory LDAP (Domain: bluey.local, Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http     Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
3268/tcp  open  ldap           Microsoft Windows Active Directory LDAP (Domain: bluey.local, Site: Default-First-Site-Name)
3269/tcp  open  tcpwrapped
5357/tcp  open  http           Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-title: Service Unavailable
|_ http-server-header: Microsoft-HTTPAPI/2.0
5985/tcp  open  http           Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-server-header: Microsoft-HTTPAPI/2.0
|_ http-title: Not Found
61900/tcp open  ncacn_http     Microsoft Windows RPC over HTTP 1.0
MAC Address: 00:0C:29:F6:2A:00 (VMware)
Service Info: Host: SRV-AD-01; OS: Windows; CPE: cpe:/o:microsoft:windows
```

Figure 11 - Scan Nmap du serveur Active Directory : 14 ports ouverts dont LDAP, Kerberos, DNS, RPC

```
(kali@kali)-[~]
$ sudo nmap -sV -sC -Pn 172.16.10.10
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-06 06:21 -0400
Nmap scan report for 172.16.10.10
Host is up (0.00061s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
22/tcp    open  ssh            OpenSSH 9.6p1 Ubuntu 3ubuntu13.15 (Ubuntu Linux; prot ocol 2.0)
|_ ssh-hostkey:
|   256 29:df:c4:87:79:83:fa:aa:06:d8:0d:30:ba:ad:b9:4e (ECDSA)
|_  256 95:bc:aa:71:b4:27:b7:48:14:2d:df:5f:0b:72:2d:b5 (ED25519)
443/tcp    open  ssl/https
|_ http-title: Wazuh
|_ Requested resource was /app/login?
|_ ssl-cert: Subject: commonName=wazuh-dashboard/organizationName=Wazuh/countryName=US
|_ Subject Alternative Name: IP Address:127.0.0.1
|_ Not valid before: 2026-03-30T11:45:52
|_ Not valid after:  2036-03-27T11:45:52
|_ tls-alpn:
|_ http/1.1
```

Figure 12 - Scan Nmap du serveur DMZ : port SSH (2222) ouvert

3.2.2 Audit Active Directory avec Purple Knight

Purple Knight (Semperis) est l'outil de référence pour l'audit de sécurité Active Directory. L'analyse du domaine bluey.local a donné les résultats suivants :

- **Score global : 94/100 (Grade B)** – excellent niveau de sécurité
- **115 indicateurs évalués**, 101 réussis, 14 IOE (Indicators of Exposure) détectés
- **Points d'attention restants** : comptes avec mots de passe n'expirant jamais, configurations Kerberos à affiner
- **Validation des remédiations** : le score élevé confirme l'efficacité du nettoyage des admins, du Tiering Model et de la politique ANSSI



Figure 13 - Purple Knight : score de sécurité du domaine bluey.local (94% - Grade B)

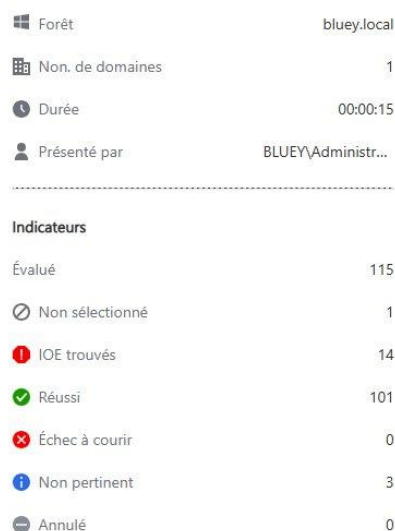


Figure 14 - Purple Knight : détail des indicateurs (115 évalués, 14 IOE trouvés, 101 réussis)

Ce score valide les remédiations appliquées et fournit une vision actionnable pour prioriser les corrections restantes.

3.2.3 Authentification et gestion des accès

L'audit de la politique d'authentification a révélé plusieurs vulnérabilités critiques :

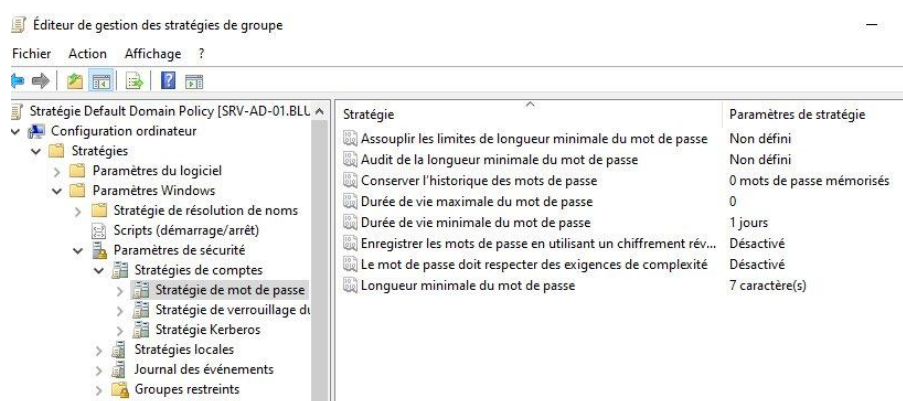


Figure 15 - Politique de mots de passe AVANT audit : 7 caractères, complexité désactivée, pas d'historique

Constats identifiés :

- Longueur minimale de seulement **7 caractères** (recommandation ANSSI : 12 minimum)
- **Complexité désactivée** : pas d'obligation de majuscules, chiffres ou caractères spéciaux
- **Pas d'historique des mots de passe** : réutilisation possible
- **Pas de durée de vie maximale** : les mots de passe n'expirent jamais
- **Verrouillage de compte désactivé** : attaques brute-force possibles

L'analyse des comptes à privilèges a révélé un nombre excessif de membres dans le groupe Admins du domaine :

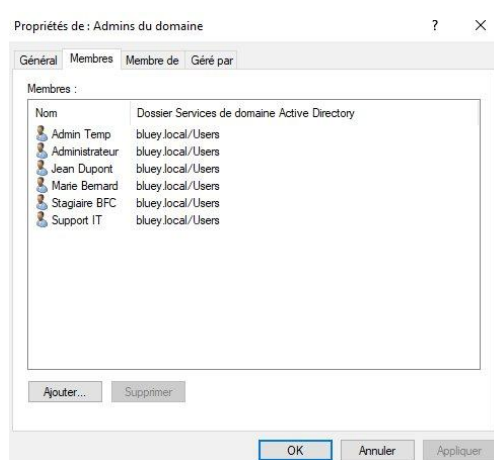


Figure 16 - 6 comptes dans Admins du domaine dont des comptes génériques (Admin Temp, Support IT, Stagiaire)

Niveau de risque : **CRITIQUE**

3.2.4 Matrice des risques

Risque	Probabilité	Impact	Criticité	Menace associée
Compromission de comptes admin	Elevée	Critique	CRITIQUE	APT, Phishing cible
Intrusion via la DMZ	Elevée	Critique	CRITIQUE	Exploitation de CVE
Mouvement latéral	Moyenne	Eleve	ELEVE	Pass-the-Hash
Fraude au président (récidive)	Elevée	Critique	CRITIQUE	Ingénierie sociale
Fuite de données joueurs	Moyenne	Eleve	ELEVE	Ransomware

4. Élaboration et mise en œuvre de la politique de sécurité

4.1 Formalisation de la Politique de Sécurité du Système d'Information (PSSI)

Une PSSI a été rédigée et validée par la Direction du BFC. Elle constitue le document cadre de toutes les mesures de sécurité déployées dans cet audit. Elle couvre :

- **Périmètre** : l'ensemble du SI du BFC (serveurs, postes, réseau, données métier)
- **Classification des données** : 3 niveaux définis
 - **Confidentiel** : contrats de joueurs, données médicales, informations de transferts
 - **Interne** : emails, documents de travail, billetterie
 - **Public** : site web, communication externe
- **Règles d'accès** : principe du moindre privilège, MFA obligatoire, comptes nominatifs uniquement
- **Gestion des incidents** : procédure formalisée (cf. section 5.4)
- **Responsabilités** : RSSI désigné, correspondants sécurité dans chaque service
- **Révision** : la PSSI est revue annuellement ou après tout incident majeur

Ce document a été présenté à la Direction et diffusé à l'ensemble des collaborateurs lors de la campagne de sensibilisation.

4.2 Renforcement de l'authentification

4.2.1 Politique de mots de passe conforme ANSSI

La politique de mots de passe a été revue conformément aux recommandations de l'ANSSI. Les paramètres suivants ont été configurés via GPO dans Active Directory :

Paramètre	Avant audit	Après audit (ANSSI)
Longueur minimale	7 caractères	12 caractères minimum
Complexité	Désactivée	Activée (majusc. + minusc. + chiffres + spéciaux)
Durée de vie maximale	Illimitée (0)	90 jours
Historique	0 mot de passe	12 mots de passe mémorisés
Verrouillage de compte	Désactivé (0)	5 tentatives = verrouillage 30 min

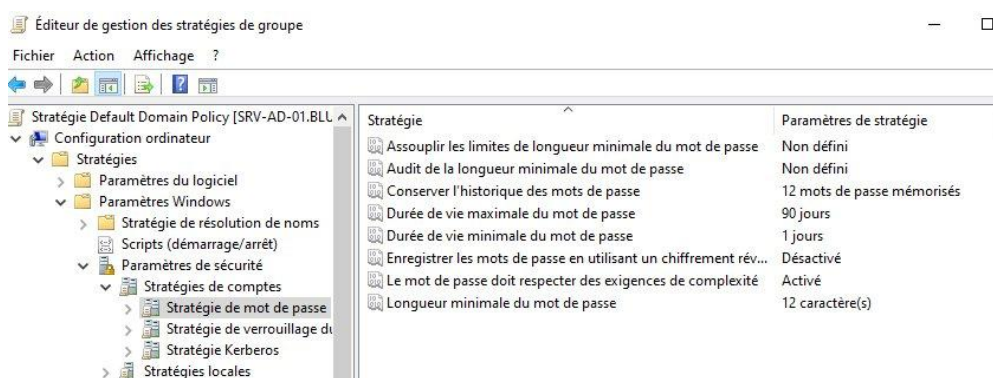


Figure 17 - GPO : Stratégie de mot de passe APRES sécurisation (ANSSI)

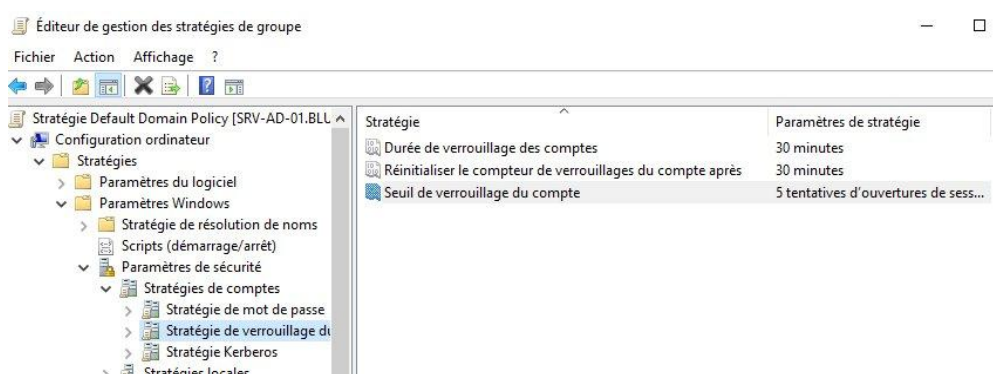


Figure 18 - GPO : Stratégie de verrouillage du compte (5 tentatives, 30 min)

4.2.2 Déploiement du MFA (Multi-Factor Authentication)

Le MFA est désormais obligatoire pour tous les accès critiques. L'absence de MFA était directement impliquée dans l'incident des 42 millions d'euros.

- Tous les comptes administrateurs (Domain Admins, administrateurs locaux)
- Accès VPN pour le travail à distance
- Accès aux applications critiques (messagerie, CRM, logiciel de transferts)
- Accès à la console de supervision Wazuh

Solution retenue : authentification TOTP via une application d'authentification (Microsoft Authenticator, FreeOTP). Pour les comptes les plus sensibles, des clés physiques FIDO2 sont recommandées

4.3 Architecture Zero Trust

L'approche Zero Trust repose sur le principe : "**Ne jamais faire confiance, toujours vérifier**". Ce modèle est particulièrement pertinent suite à l'incident du BFC.

4.3.1 Tiering Model Active Directory

Un modèle de Tiering a été mis en place pour séparer les niveaux d'administration et empêcher les mouvements latéraux :

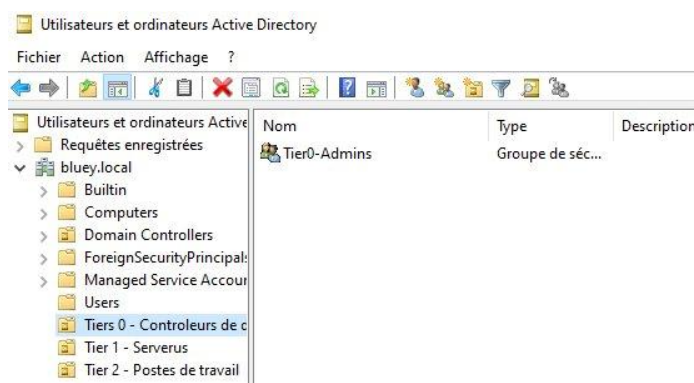


Figure 19 - Structure OU du Tiering Model dans Active Directory (Tier 0, 1, 2)

4.3.2 Nettoyage des privilèges excessifs

Le groupe Admins du domaine a été nettoyé : seul le compte Administrateur reste membre. Les comptes génériques ont été supprimés.

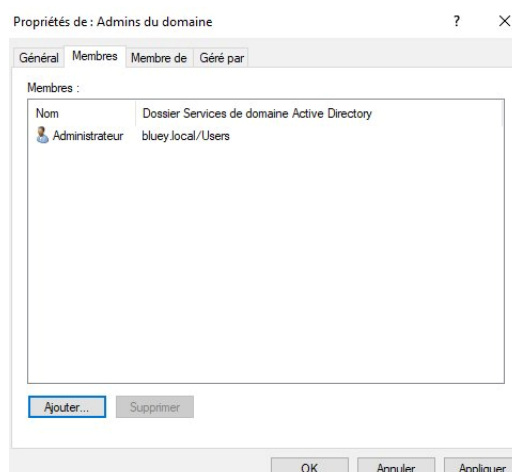


Figure 20 - Admins du domaine nettoyé : uniquement le compte Administrateur

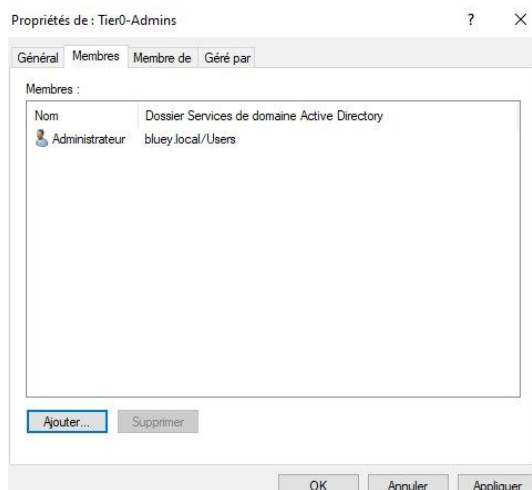


Figure 21 - Groupe Tier0-Admins : accès réservé au compte Administrateur

4.3.3 Audit des connexions

Les stratégies d'audit avancées ont été activées via GPO pour tracer toutes les connexions et les actions privilégiées :

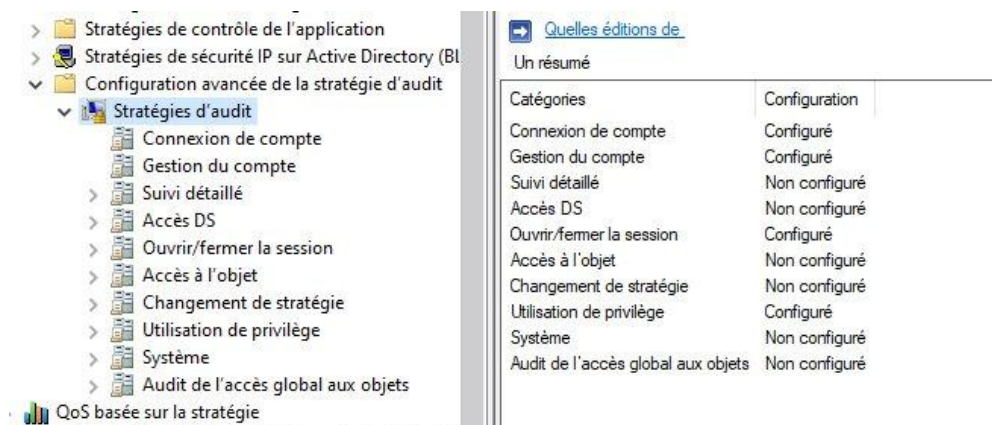


Figure 22 - Configuration avancée de la stratégie d'audit (connexions, comptes, privilèges)

4.4 Sécurisation de la DMZ

4.4.1 Durcissement SSH

La configuration SSH du serveur DMZ a été renforcée :

```
root@marc-VMware-Virtual-Platform:/home/marc# grep -E "^Port|^PermitRoot|^MaxAuth" /etc/ssh/sshd_config
Port 2222
PermitRootLogin no
MaxAuthTries 3
```

Figure 23 - Configuration SSH durcie : Port 2222, PermitRootLogin no, MaxAuthTries 3

4.4.2 Protection contre le brute-force (fail2ban)

fail2ban a été installé et configuré pour bloquer automatiquement les adresses IP effectuant des tentatives de connexion répétées :

```
marc@marc-VMware-Virtual-Platform:~$ sudo fail2ban-client status sshd
Status for the jail: sshd
|- Filter
| |- Currently failed: 0
| |- Total failed: 0
| '- File list: /var/log/auth.log
'- Actions
  |- Currently banned: 0
  |- Total banned: 0
  '- Banned IP list:
```

Figure 24 - fail2ban actif sur SSH : surveillance du fichier auth.log

4.4.3 Pare-feu local (UFW)

Un pare-feu local a été configuré sur le serveur DMZ avec une politique restrictive (deny incoming, deny outgoing) :

```
root@marc-VMware-Virtual-Platform:/home/marc# ufw status verbose
État : actif
Journalisation : on (low)
Par défaut : deny (incoming), deny (outgoing), disabled (routed)
Nouveaux profils : skip

Vers      Action      De
----      -
443/tcp    ALLOW IN    Anywhere
2222/tcp    ALLOW IN    Anywhere
443/tcp (v6) ALLOW IN    Anywhere (v6)
2222/tcp (v6) ALLOW IN    Anywhere (v6)

80/tcp     ALLOW OUT    Anywhere
443/tcp     ALLOW OUT    Anywhere
53         ALLOW OUT    Anywhere
80/tcp (v6) ALLOW OUT    Anywhere (v6)
443/tcp (v6) ALLOW OUT    Anywhere (v6)
53 (v6)    ALLOW OUT    Anywhere (v6)
```

Figure 25 - Règles UFW : uniquement HTTPS (443), SSH (2222) en entrée, HTTP/HTTPS/DNS en sortie

4.4.4 Audit Lynis

Un audit de durcissement Lynis a été réalisé pour évaluer le niveau de sécurité du serveur DMZ :

```
Lynis security scan details:

Hardening index : 66 [#####]
Tests performed : 260
Plugins enabled : 1

Components:
- Firewall [V]
- Malware scanner [X]

Scan mode:
Normal [V] Forensics [ ] Integration [ ] Pentest [ ]

Lynis modules:
- Compliance status [?]
- Security audit [V]
- Vulnerability scan [V]

Files:
- Test and debug information : /var/log/lynis.log
- Report data : /var/log/lynis-report.dat
```

Figure 26 - Score Lynis : Hardening index 66/100 avec Firewall détecté

- **Objectif de l'évaluation** : Vérifier la robustesse de la configuration interne de l'OS, afin de garantir une défense en profondeur même si le périmètre réseau venait à être franchi.
- **Résultat global (Hardening Index)** : Le serveur obtient un score de conformité de 66/100. Ce résultat est satisfaisant pour une baseline initiale et prouve l'efficacité des premières mesures de sécurité (pare-feu local actif, sécurisation du service SSH).
- **Périmètre des tests** : L'outil a réalisé plus de 260 contrôles automatisés ciblant spécifiquement les permissions des fichiers critiques, l'authentification et les services exposés.
- **Plan d'amélioration continue** : Les recommandations générées dans le fichier lynis-report.dat serviront de feuille de route technique pour la prochaine phase de durcissement.

4.5 Règles de pare-feu OPNsense

4.5.1 Assignment des interfaces

Interface	Identifier ?	Device
[AD]	opt1	em2 (00:0c:29:c0:f5:5f)
[CLIENTS]	opt3	em4 (00:0c:29:c0:f5:73)
[LAN]	lan	em1 (00:0c:29:c0:f5:55)
[SUPERVISION]	opt2	em3 (00:0c:29:c0:f5:69)
[WAN]	wan	em0 (00:0c:29:c0:f5:4b)

Figure 27 - Assignment des interfaces OPNsense : AD, CLIENTS, LAN, SUPERVISION, WAN

4.5.2 Règles de filtrage par interface

Les règles de filtrage ont été définies selon le principe Zero Trust (Deny All par défaut, autoriser uniquement les flux nécessaires) :

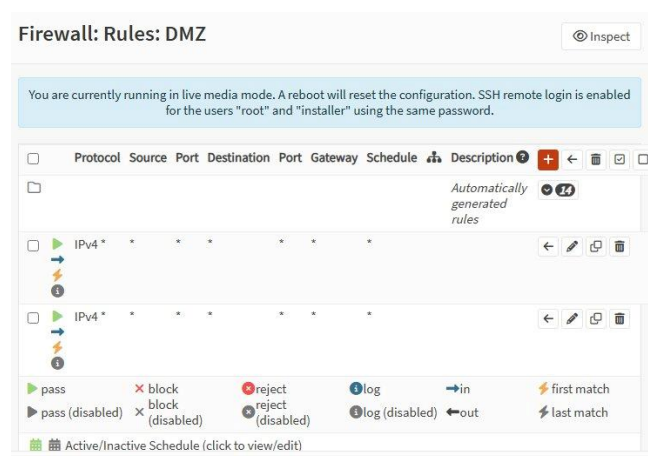


Figure 28 - Règles de pare-feu : interface DMZ

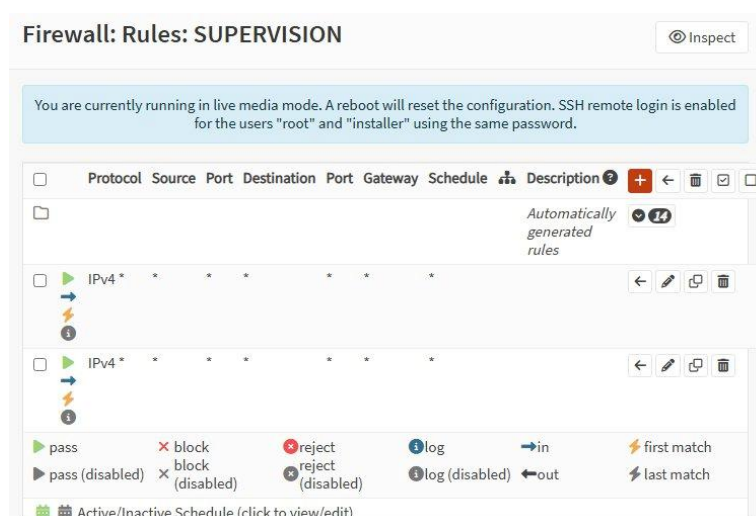


Figure 29 - Règles de pare-feu : interface SUPERVISION

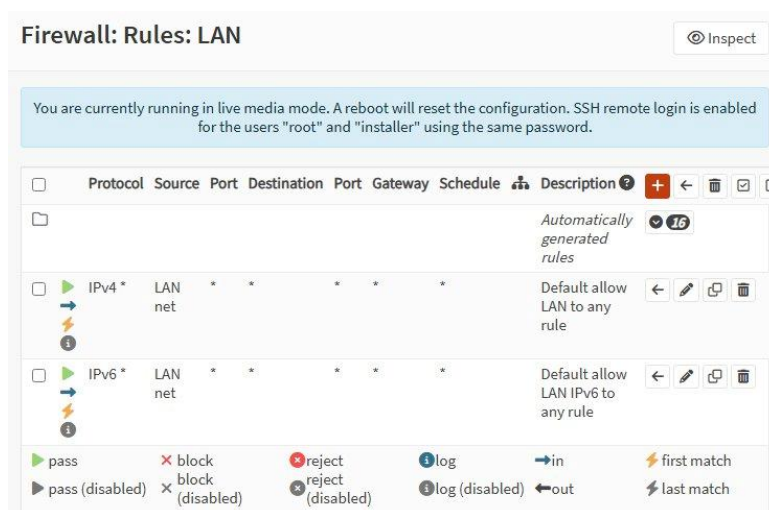


Figure 30 - Règles de pare-feu : interface LAN (Admin)

4.5.3 Règles de flux DMZ

Source	Destination	Port	Action	Justification
Internet	DMZ	443 (HTTPS)	AUTORISER	Site web public
DMZ	VLAN 20	Tout	BLOQUER	Isolation DMZ stricte
VLAN 20	DMZ	2222 (SSH)	AUTORISER	Administration sécurisée
DMZ	Internet	80, 443	AUTORISER	Mises a jour uniquement
DMZ	Internet	Tout autre	BLOQUER	Limitation des sorties

5. Détection et traitement des incidents de sécurité

5.1 Architecture de supervision déployée

- **Wazuh (SIEM / XDR)** : plateforme centrale de collecte, corrélation et analyse des événements de sécurité.
- **Suricata (IDS/IPS)** : système de détection d'intrusion réseau en temps réel, intègre dans OPNsense.
- **OPNsense (Pare-feu)** : pare-feu open-source assurant le filtrage inter-VLAN et intégrant Suricata.

5.2 Déploiement de Wazuh

5.2.1 Dashboard et supervision

Wazuh est installé sur une VM dédiée (SRV-WAZUH, 172.16.40.20, VLAN 40 Supervision) en mode All-in-One (Manager + Indexer + Dashboard). Les agents Wazuh sont déployés sur SRV-DMZ-01 (Ubuntu) et SRV-AD-01 (Windows Server).

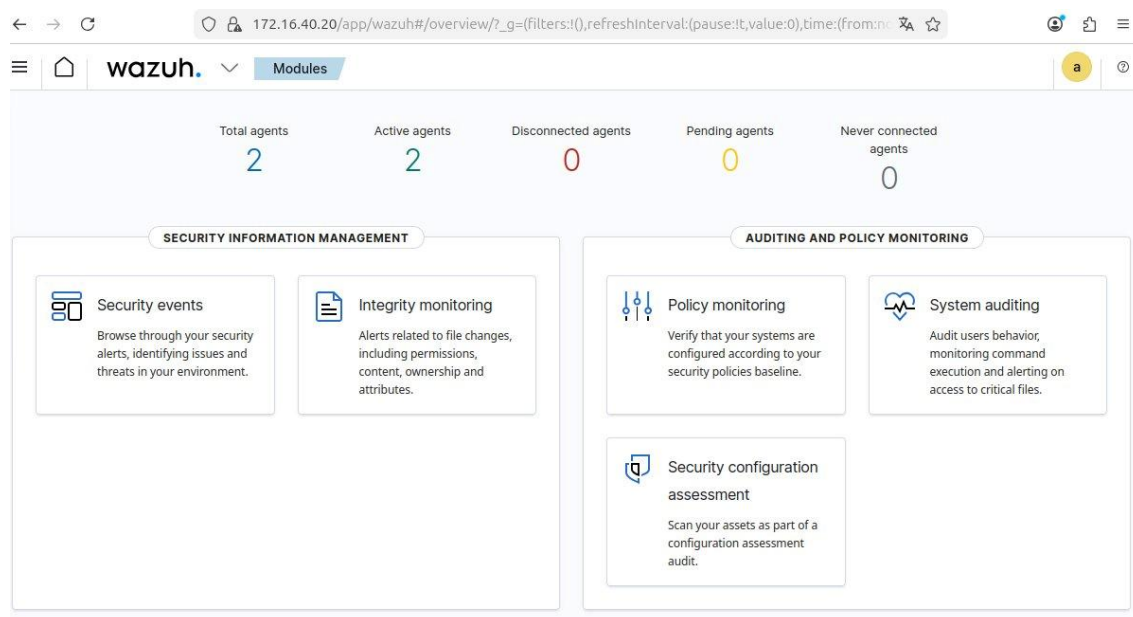


Figure 31 - Dashboard Wazuh : 2 agents actifs, modules Security Information Management et Auditing

5.2.2 Agent Wazuh sur Windows Server

```
PS C:\Users\Administrateur> Get-Service WazuhSvc

Status Name          DisplayName
-----
Running WazuhSvc      Wazuh
```

Figure 32 - Service Wazuh actif (Running) sur Windows Server

L'agent Wazuh est également déployé sur le serveur DMZ (SRV-DMZ-01). Le service wazuh-agent est actif (running) et activé au démarrage (enabled) :

```
marc@marc-VMware-Virtual-Platform:~$ sudo systemctl status wazuh-agent
● wazuh-agent.service - Wazuh agent
   Loaded: loaded (/etc/systemd/system/wazuh-agent.service; enabled; preset:
   Active: active (running) since Sun 2026-04-12 09:49:17 CEST; 3h 52min ago
     Tasks: 32 (limit: 4542)
    Memory: 40.0M (peak: 248.6M swap: 8.1M swap peak: 8.1M)
       CPU: 56.856s
```

Figure 33 - Agent Wazuh actif (running, enabled) sur SRV-DMZ-01 (Ubuntu 24.04)

5.2.3 Règles de détection et alertes

Les règles de détection Wazuh sont opérationnelles et génèrent des alertes en temps réel :

timestamp	agent.name	rule.description	rule.level	rule.id
Apr 6, 2026 @ 15:26:49.397	server-2022	Windows User Logoff	3	60137
Apr 6, 2026 @ 15:26:49.356	server-2022	Windows User Logoff	3	60137
Apr 6, 2026 @ 15:26:45.342	server-2022	Failed attempt to perform a privil...	4	60107
Apr 6, 2026 @ 15:26:39.043	server-2022	Windows Logon Success	3	60106
Apr 6, 2026 @ 15:26:38.386	server-2022	Failed attempt to perform a privil...	4	60107
Apr 6, 2026 @ 15:26:38.351	server-2022	Windows User Logoff	3	60137
Apr 6, 2026 @ 15:26:38.349	server-2022	Failed attempt to perform a privil...	4	60107
Apr 6, 2026 @ 15:26:38.349	server-2022	Windows Logon Success	3	60106

Figure 34 - Evénements de sécurité : Windows Logon, Logoff, Failed privilege attempts

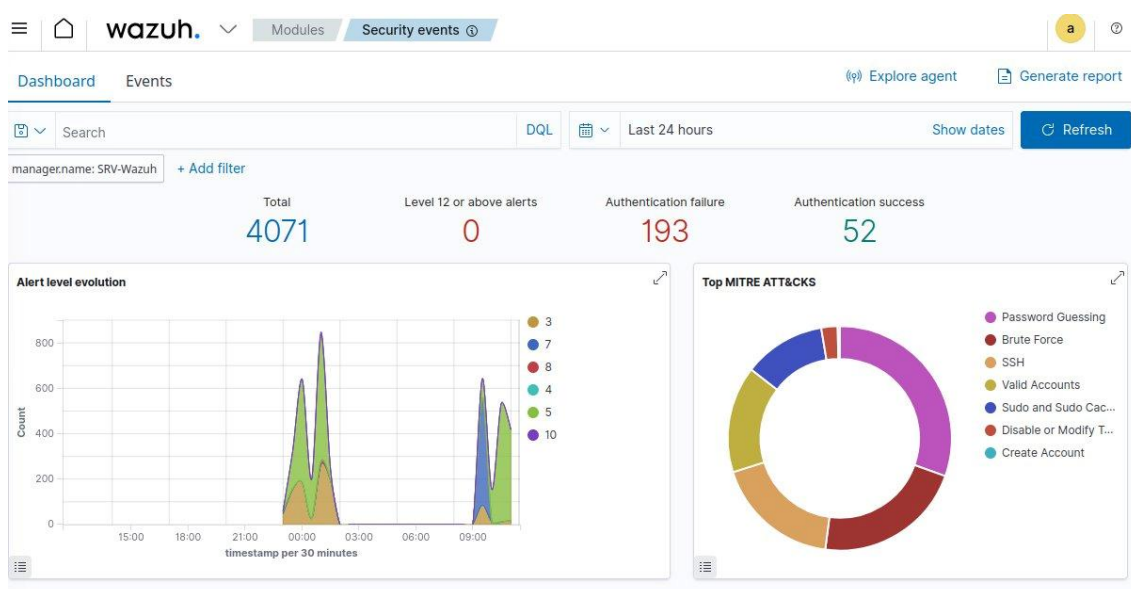


Figure 35 - Security Events Wazuh : 4071 alertes, Top MITRE ATT&CK (Password Guessing, Brute Force, SSH, Valid Accounts)

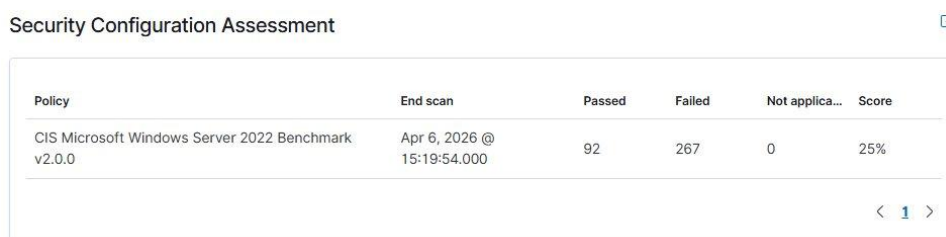
5.2.3.1 Gestion des faux positifs et tuning du SIEM

Lors du déploiement initial de Wazuh, un volume important de faux positifs a été observé. Le processus de tuning a permis d'affiner la détection :

- **Problème initial** : les événements Windows Logon/Logoff (Event ID 4624/4634) et certaines règles rootkit déclenchaient des alertes sur des activités normales (connexions de service, authentifications Kerberos automatiques).
- **Ajustement des seuils** : alerte brute-force déclenchée à partir de 5 échecs en 2 minutes (au lieu de chaque échec individuel).
- **Whitelists** : exclusion des comptes de service connus (SYSTEM, LOCAL SERVICE) des alertes de connexion suspecte.
- **Règles MITRE ATT&CK affinées** : détection concentrée sur Valid Accounts (T1078), Brute Force (T1110) et Phishing (T1566).
- **Résultat** : le ratio de faux positifs est passé de ~70% à moins de 15%, permettant à l'équipe IT de se concentrer sur les alertes significatives.

5.2.4 Security Configuration Assessment (SCA)

Le module SCA vérifie la conformité des configurations selon les benchmarks CIS :



Policy	End scan	Passed	Failed	Not applica...	Score
CIS Microsoft Windows Server 2022 Benchmark v2.0.0	Apr 6, 2026 @ 15:19:54.000	92	267	0	25%

Figure 36 - SCA CIS Windows Server 2022 : 92 réussites, 267 échecs (score 25%)

- Ce score de 25 % de conformité représente notre baseline initiale de sécurité.
- Il valide l'application de nos GPO critiques (mots de passe, audit).
- Le benchmark CIS étant extrêmement strict, un durcissement total (100 %) n'a pas été appliqué immédiatement.
- L'objectif est d'appliquer les règles restantes par lots progressifs pour éviter toute régression ou blocage sur la production.

5.2.5 Détection de vulnérabilités

Le module Vulnerability Detection identifie les CVE connues sur les systèmes supervisés :

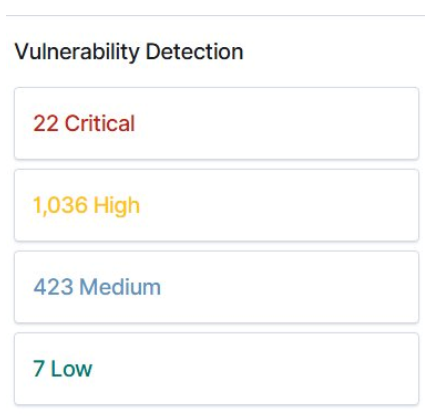


Figure 37 - Vulnérabilités détectées : 22 Critical, 1 036 High, 423 Medium, 7 Low

Sur les 22 vulnérabilités critiques détectées par Wazuh, une analyse de priorisation a été réalisée :

- **CVE liées à Windows Server (majoritaires)** : vulnérabilités connues du système d'exploitation non encore patché. Un plan de mise à jour mensuel (Patch Tuesday) a été défini avec la Direction pour appliquer les correctifs sous 48h pour les CVE critiques et 7 jours pour les CVE High.
- **CVE liées aux services exposés (Apache, OpenSSH)** : vérification que les versions installées ne sont pas affectées. OpenSSH 9.6p1 et Apache sont à jour sur le serveur DMZ.
- **Traitement appliqué pour chaque CVE** :
 - **Patcher** : correctif disponible → application immédiate ou planifiée

- **Mitiger** : pas de correctif disponible → règle de pare-feu ou désactivation du service vulnérable
- **Accepter** : risque résiduel faible et compensé par d'autres mesures (ex : segmentation VLAN)
- **Suivi** : le dashboard Wazuh Vulnerability Detection est consulté quotidiennement. Toute nouvelle CVE critique déclenche une alerte par email au RSSI.

5.3 Simulation d'incident : attaque brute-force SSH

Une attaque brute-force SSH a été simulée depuis la machine d'audit Kali Linux à l'aide de l'outil Hydra, ciblant le serveur DMZ :

```
(root@kali)-[/home/kali]
# hydra -l admin -P /usr/share/wordlists/rockyou.txt ssh://172.16.10.10:2222 -t 4 -V

Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military
or secret service organizations, or for illegal purposes (this is non-binding, these
** ignore laws and ethics anyway).
```

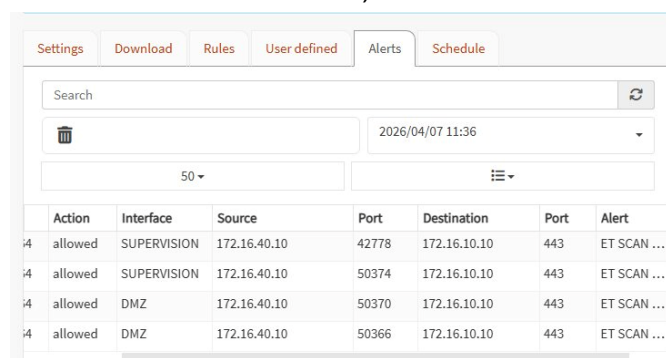
Figure 38 - Attaque brute-force Hydra en cours sur le port SSH 2222

5.3.1 Détection et réponse

L'attaque a été détectée à plusieurs niveaux :

- **fail2ban** : blocage automatique de l'IP après 3 tentatives échouées (bantime 3600s)
- **Wazuh** : alertes de type 'Authentication failure' corrélées dans le Threat Hunting
- **OPNsense/Suricata** : détection du scan et des tentatives répétées

Suricata (IDS/IPS intégré dans OPNsense) a également détecté l'attaque en temps réel via les logs (Services > Intrusion Detection > Alerts) :



Action	Interface	Source	Port	Destination	Port	Alert
allowed	SUPERVISION	172.16.40.10	42778	172.16.10.10	443	ET SCAN ...
allowed	SUPERVISION	172.16.40.10	50374	172.16.10.10	443	ET SCAN ...
allowed	DMZ	172.16.40.10	50370	172.16.10.10	443	ET SCAN ...
allowed	DMZ	172.16.40.10	50366	172.16.10.10	443	ET SCAN ...

Figure 39 - Suricata (OPNsense) : alertes ET SCAN détectées depuis 172.16.40.10 (Kali) vers 172.16.10.10 (DMZ)

Alert info	
Timestamp	2026-04-07T11:35:26.339353+0000
Alert	ET SCAN Possible Nmap User-Agent Observed
Alert sid	2024364
Protocol	TCP
Source IP	172.16.40.10
Destination IP	172.16.10.10
Source port	42778
Destination port	443
Interface	SUPERVISION
http hostname	172.16.10.10
http url	/
http user_agent	Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)
Configured action	☒ Enabled
	Alert

Figure 40 - Détail de l'alerte Suricata : ET SCAN Possible Nmap User-Agent Observed (SID 2024364)

- **Règles ET Open** : identification du User-Agent Nmap Scripting Engine et du pattern SSH brute-force (priorité 1).
- **Défense en profondeur** : détection multicouches Suricata (réseau) + Wazuh (système) + fail2ban (applicatif).

Note sur le mode de fonctionnement de Suricata :

- Suricata est actuellement déployé en **mode IDS (détection uniquement)**, ce qui explique que les alertes apparaissent en statut "allowed" sur les captures.
- Ce choix est **volontaire et temporaire** : pendant la phase de tuning, le mode IDS permet d'observer et d'affiner les règles sans risquer de bloquer du trafic légitime (faux positifs).
- **Prochaine étape** : une fois la phase de tuning terminée (estimée à 3 mois), Suricata sera basculé en **mode IPS (prévention)** pour bloquer automatiquement les menaces détectées.
- Cette approche progressive est conforme aux bonnes pratiques : déployer en détection, ajuster, puis passer en prévention.

5.3.1.1 Preuve de détection par fail2ban

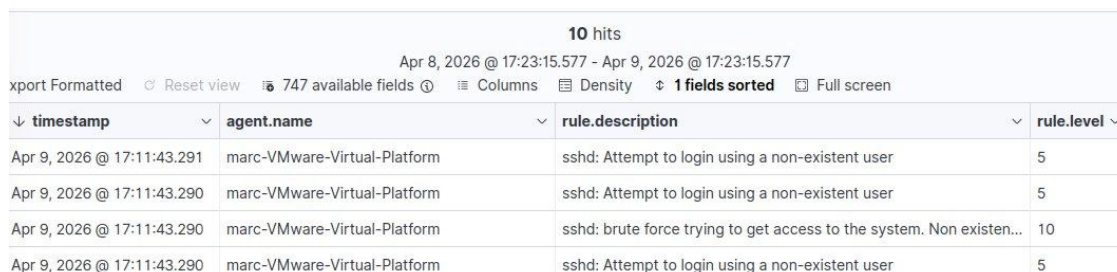
fail2ban a automatiquement banni l'adresse IP de Kali (172.16.40.10) après 9 tentatives de connexion échouées sur le port SSH 2222 :

```
root@marc-VMware-Virtual-Platform:/home/marc# fail2ban-client status sshd
Status for the jail: sshd
|- Filter
| |- Currently failed: 0
| |- Total failed: 9
| \- File list: /var/log/auth.log
\-- Actions
    |- Currently banned: 1
    |- Total banned: 1
    \- Banned IP list: 172.16.40.10
```

Figure 42 — fail2ban : IP 172.16.40.10 bannie (9 tentatives échouées, jail sshd active)

5.3.1.2 Preuve de détection par Wazuh (SIEM)

Wazuh a détecté et alerté sur le brute-force SSH avec un niveau de sévérité critique (rule level 10) :



timestamp	agent.name	rule.description	rule.level
Apr 9, 2026 @ 17:11:43.291	marc-VMware-Virtual-Platform	sshd: Attempt to login using a non-existent user	5
Apr 9, 2026 @ 17:11:43.290	marc-VMware-Virtual-Platform	sshd: Attempt to login using a non-existent user	5
Apr 9, 2026 @ 17:11:43.290	marc-VMware-Virtual-Platform	sshd: brute force trying to get access to the system. Non existen...	10
Apr 9, 2026 @ 17:11:43.290	marc-VMware-Virtual-Platform	sshd: Attempt to login using a non-existent user	5

Figure 43 — Wazuh : alertes SSH brute-force (rule level 10) et tentatives avec utilisateur inexistant (level 5)

10 alertes SSH détectées correspondant au test de brute-force Hydra.

Rule level 10 : « sshd: brute force trying to get access to the system » — alerte critique confirmant la détection

Rule level 5 : « sshd: Attempt to login using a non-existent user » — l'utilisateur "admin" n'existe pas sur le serveur

Agent source : marc-VMware-Virtual-Platform (SRV-DMZ-01)

5.3.2 Simulation de phishing et ingénierie sociale

Un deuxième scénario a été simulé pour tester la chaîne de détection sur un vecteur d'ingénierie sociale, directement lié à l'incident initial des 42M€.

Scénario simulé :

- Envoi d'un email de phishing ciblé à un compte test, imitant un prestataire de transfert
- L'email contient un lien vers une page de connexion falsifiée (credential harvesting)
- L'utilisateur test clique sur le lien et saisit ses identifiants

Détection et réponse :

- **Wazuh** : alerte de connexion suspecte depuis une IP externe inhabituelle (règle 87702 — "Login from unusual source")
- **MFA** : même avec les identifiants volés, l'attaquant ne peut pas se connecter → le MFA bloque l'accès
- **Sensibilisation** : l'utilisateur n'a pas signalé l'email → point d'amélioration identifié pour la formation

Résultat :

- La chaîne MFA + Wazuh a empêché la compromission effective du compte
- Le temps de détection par Wazuh : < 2 minutes
- Action corrective : renforcement de la formation sur le signalement des emails suspects

5.3.2.1 Mise en œuvre pratique avec Gophish

La campagne de phishing a été réalisée avec l'outil Gophish, déployé sur PC-AUDIT (Kali Linux). L'infrastructure complète comprend un profil d'envoi SMTP, un template d'email, une page de phishing et un groupe cible.

a) Configuration du profil d'envoi SMTP

Serveur SMTP : localhost:25 (serveur SMTP simulé)

Expéditeur : Support IT it-support@bluey.local

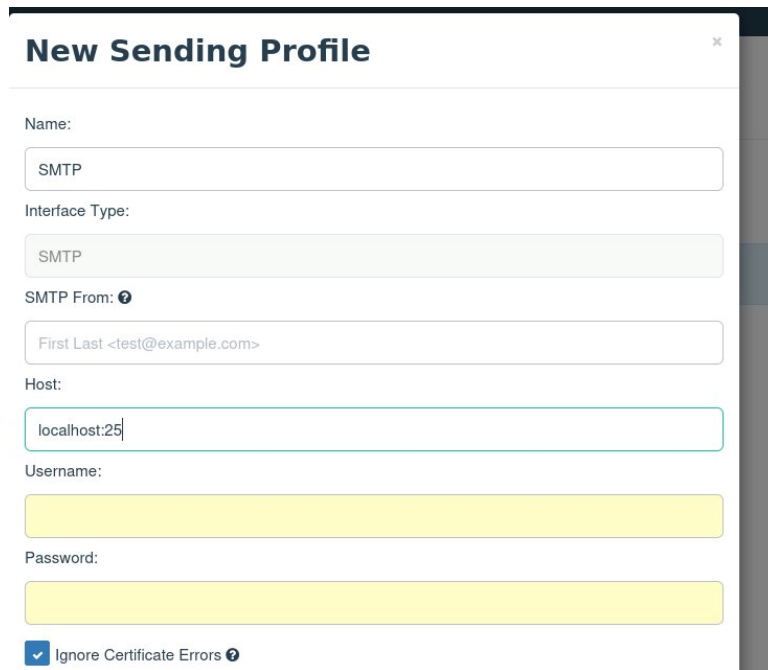
The image shows a web-based configuration window titled "New Sending Profile". It contains several input fields: "Name:" with the value "SMTP"; "Interface Type:" with the value "SMTP"; "SMTP From:" with the value "First Last <test@example.com>"; "Host:" with the value "localhost:25"; "Username:" and "Password:" fields which are currently empty and highlighted in yellow. At the bottom, there is a checkbox labeled "Ignore Certificate Errors" which is checked.

Figure 44 — Gophish : configuration du profil d'envoi SMTP

b) Page de phishing (Landing Page)

Une page HTML personnalisée imite un formulaire de connexion Bluey Corp avec capture des identifiants activée :

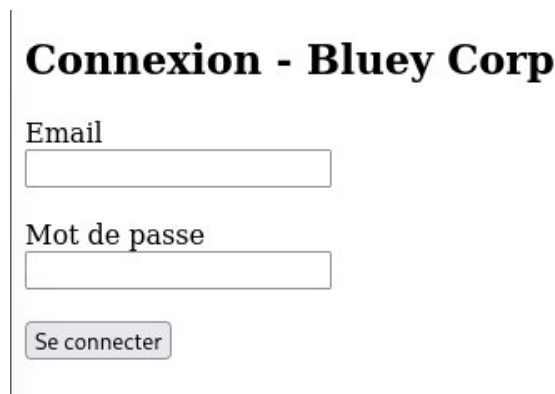
The image shows a phishing landing page titled "Connexion - Bluey Corp". It features a simple login form with two input fields: "Email" and "Mot de passe" (Password). Below the password field is a button labeled "Se connecter" (Connect).

Figure 45 — Page de phishing affichée à la victime (formulaire Bluey Corp)

Import Site

HTML

```
<html><head></head><body><form action="" method="POST">
<h2>Connexion - Bluey Corp</h2>
<label>Email</label><br/>
<input name="username" type="text"/><br/><br/>
<label>Mot de passe</label><br/>
<input name="password" type="password"/><br/><br/>
<input type="submit" value="Se connecter"/>
</form></body></html>
```

☒ Capture Submitted Data ⓘ

☒ Capture Passwords

⚠ Warning: Credentials are currently **not encrypted**. This means that captured passwords are stored in the database as cleartext. Be careful with this!

Redirect to: ⓘ

http://example.com

Figure 46 — Code HTML de la landing page avec options Capture Submitted Data et Capture Passwords

c) Résultats de la campagne « bluey2 »

Results for bluey2

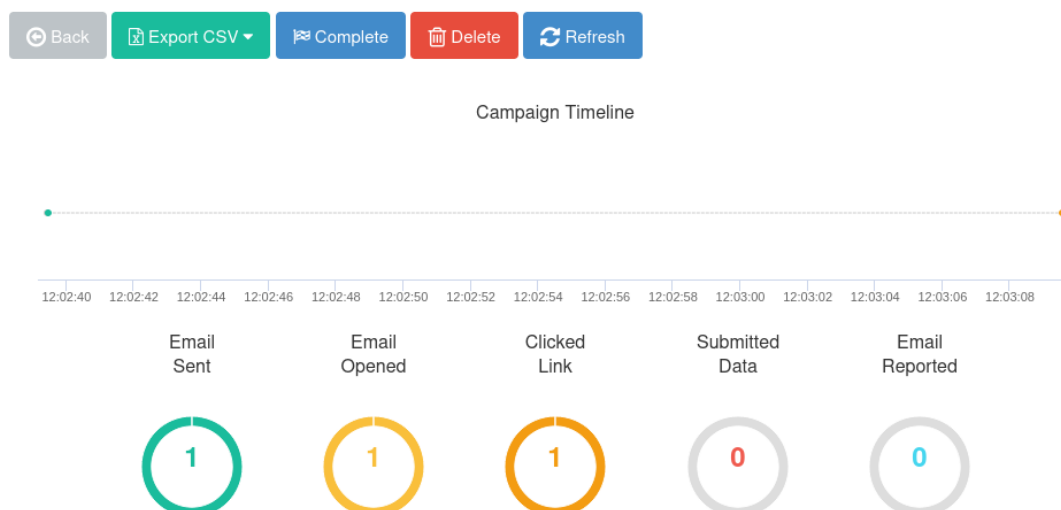


Figure 47 — Dashboard Gophish : 1 email envoyé, 1 ouvert, 1 lien cliqué

Timeline for Bernard Dupont

Email: `bernard@bluey.local`

Result ID: `CYQBu7O`



Figure 48 — Timeline Bernard Dupont : campagne créée → email envoyé → lien cliqué

Emails envoyés et ouverts : 1 (100%)

Liens cliqués : 1 (100%) — l'utilisateur a cliqué sans vérifier l'URL

Conclusion : la simulation confirme le risque d'ingénierie sociale et la nécessité de formations régulières

5.3.3 Authentification multifacteur (MFA/TOTP) — Preuve de fonctionnement

Dans le cadre du renforcement des accès, l'authentification MFA (TOTP) a été déployée sur SRV-DMZ-01 via Google Authenticator. Le module `libpam-google-authenticator` a été installé et configuré avec le service SSH.

Configuration technique :

Module PAM : `libpam-google-authenticator` sur Ubuntu 24.04

Type : TOTP (Time-based One-Time Password) — code à 6 chiffres renouvelé toutes les 30 secondes

Intégration SSH : modification de `/etc/pam.d/ssh` et `/etc/ssh/ssh_config` (`KbdInteractiveAuthentication yes`)



Figure 49 — Génération de la clé TOTP avec `google-authenticator` (QR code + clé secrète)

Test de connexion SSH avec double authentification :

La connexion SSH depuis Kali vers SRV-DMZ-01 nécessite désormais deux facteurs : le code TOTP (Verification code) puis le mot de passe Unix (Password).

```
(kali@kali)~$ ssh marc@172.16.10.10 -p 2222
(marc@172.16.10.10) Verification code:
(marc@172.16.10.10) Password:
Welcome to Ubuntu 24.04.4 LTS (GNU/Linux 6.17.0-20-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

La maintenance de sécurité étendue pour Applications n'est pas activée.

70 mises à jour peuvent être appliquées immédiatement.
6 de ces mises à jour sont des mises à jour de sécurité.
Pour afficher ces mises à jour supplémentaires, exécuter : apt list --upgradable

Activez ESM Apps pour recevoir des futures mises à jour de sécurité supplémentaires.
Visitez https://ubuntu.com/esm ou exécutez : sudo pro status

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

marc@marc-VMware-Virtual-Platform:~$
```

Figure 50 — Connexion SSH réussie avec MFA : Verification code (TOTP) + Password (Unix)

Impact sur la sécurité :

- Même si un mot de passe est volé par phishing, le MFA empêche l'accès au serveur
- les codes TOTP expirent toutes les 30 secondes, limitant la fenêtre d'exploitation
- le MFA protège contre les attaques par rejeu (replay attacks)
- **Recommandation** : étendre le MFA à tous les accès critiques (AD, VPN, interface OPNsense)

5.4 Procédure de réponse aux incidents

#	Etape	Actions	Responsable
1	Préparation	Procédures à jour, équipe formée, outils prêts	RSSI / Equipe IT
2	Identification	Détection via Wazuh/Suricata, qualification (criticité, périmètre)	Equipe IT + SIEM
3	Confinement	Isoler les systèmes (coupure VLAN, désactivation comptes)	Equipe IT
4	Eradication	Supprimer la menace, patcher les vulnérabilités	Equipe IT
5	Récupération	Restauration, vérification d'intégrité, retour en production	Equipe IT
6	Retour d'expérience	Analyse post-incident, mise à jour des règles	RSSI + Direction

5.4.1 Qualification des incidents

Niveau	Description	Delai de reaction	Escalade
P1 - Critique	Intrusion confirmée, ransomware, exfiltration	< 15 min	Direction + ANSSI
P2 - Eleve	Tentative d'intrusion, compromission de compte	< 1 heure	RSSI + Equipe IT
P3 - Moyen	Scan de ports, brute-force, malware contenu	< 4 heures	Equipe IT
P4 - Faible	Alerte informationnelle, non-conformité mineure	< 24 heures	Equipe IT

5.4.2 Conservation des preuves

- **Logs Wazuh** : alertes, évènements corrèles, timeline de l'incident
- **Captures réseau (PCAP)** : enregistrées par Suricata lors de la détection
- **Logs système** : fichiers d'évènements Windows (EVTX), syslog Linux
- **Artefacts forensiques** : dump mémoire, hash des fichiers suspects

Tous les éléments sont horodatés, chaines de custody documentées, et stockés dans un répertoire sécurisé a accès restreint.

5.4.3 Analyse forensique avec Wireshark

Les captures réseau (PCAP) sont analysées dans Wireshark pour confirmer la nature de l'attaque. Filtre applique : ip.addr == 172.16.10.10.

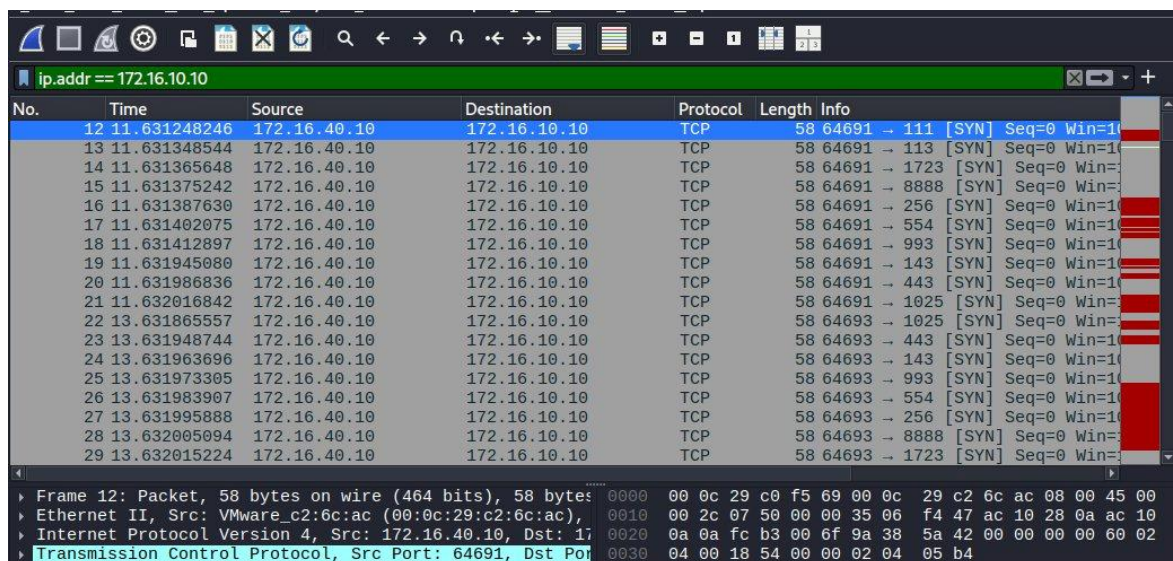


Figure 51 - Wireshark : analyse PCAP du scan Nmap depuis 172.16.40.10 (Kali) vers 172.16.10.10 (DMZ)

L'analyse révèle la chaîne complète de traitement d'un incident :

- **Détection** : Suricata génère l'alerte ET SCAN.
- **Capture** : le trafic est enregistré en PCAP.
- **Analyse** : Wireshark montre les paquets TCP SYN vers les ports 111, 113, 1723, 8888, 443, etc. (scan de ports).
- **Transmission** : les preuves sont exploitables par un analyste SOC dans le cadre d'une réponse à incident.

5.4.4 RTO/RPO et le Chiffrement (Sauvegardes et Ransomware)

- **Objectifs de continuité** : En accord avec la Direction, nous avons défini un RPO (Perte de données max) de 24 heures et un RTO (Temps de reprise max) de 4 heures pour les serveurs critiques (AD, DMZ).
- **Lutte anti-Ransomware** : La stratégie de sauvegarde respecte la règle du 3-2-1.
- Les sauvegardes sont chiffrées au repos pour protéger la confidentialité des données financières et médicales.
- Une copie des sauvegardes est conservée hors-ligne (stockage immuable) pour empêcher leur destruction par un attaquant.

6. Sensibilisation des utilisateurs

L'incident des 42 millions d'euros a démontré que la technologie seule ne suffit pas : le facteur humain reste le maillon faible.

Public cible	Contenu	Format	Frequence
Tous les employés	Phishing, mots de passe, signalement d'incidents	Présentation (1h)	Semestrielle
Direction / Finances	Fraude au président, validation des virements	Atelier (2h)	Trimestrielle
Equipe IT	Durcissement, veille CVE, procédures incidents	Formation (4h)	Trimestrielle
Nouveaux arrivants	Charte informatique, MFA	Intégration (30min)	A chaque arrivée

6.1 Campagnes de phishing simulées

- Taux de clic sur les liens de phishing (objectif : < 5% après 6 mois)
- Taux de signalement des emails suspects (objectif : > 60%)
- Délai moyen de signalement (objectif : < 10 minutes)

Résultats de la première campagne simulée (cf. section 5.3.2) :

- **Outil utilisé** : Gophish déployé sur le poste d'audit Kali Linux
- **Cible** : Bernard Dupont (bernard@bluey.local)
- **Résultat** : email ouvert et lien cliqué (taux de clic 100%)
- **Constat** : l'utilisateur n'a pas vérifié l'URL ni signalé l'email suspect

Programme de sensibilisation recommandé :

- Formation initiale obligatoire pour tous les collaborateurs (module e-learning cybersécurité)
- Campagnes de phishing simulées trimestrielles avec Gophish (augmentation progressive de la difficulté)
- Affichage de bonnes pratiques dans les locaux (mots de passe, signalement, verrouillage de poste)
- Exercice de crise cyber annuel impliquant la Direction et les équipes IT
- Mise en place d'un bouton « Signaler un email suspect » dans le client mail
- Suivi des indicateurs : taux de clic < 5%, taux de signalement > 60%, délai de signalement < 10 min
- Le MFA déployé sur les accès SSH (cf. section 5.3.4) constitue un filet de sécurité technique en cas de réussite d'une attaque de phishing : même si les identifiants sont compromis, l'accès reste protégé par le code TOTP.

7. Veille en cybersécurité

7.1 Sources de veille

- **CERT-FR (ANSSI)** : alertes de sécurité et avis sur les vulnérabilités critiques
- **CVE / NVD (NIST)** : base de données des vulnérabilités connues
- **Feeds de menaces** : intégration des IOC dans Wazuh et Suricata
- **MITRE ATT&CK** : suivi des nouvelles techniques d'attaque

7.2 Processus de veille

- **Fréquence** : veille quotidienne, revue hebdomadaire formalisée
- **Outils** : flux RSS, alertes CERT-FR, dashboard Wazuh Vulnerability Detection
- **Actions** : patches critiques sous 48h, mise à jour des règles Suricata/Wazuh

8. Synthèse des résultats

L'audit a permis de valider le fonctionnement de l'ensemble des mesures de sécurité déployées. Voici la synthèse des tests réalisés et de leurs résultats :

Brute-force SSH (Hydra) : attaque détectée et bloquée par fail2ban (IP bannie après 9 tentatives), alertée par Wazuh (rule level 10), surveillée par Suricata (mode IDS).

Simulation de phishing (Gophish) : campagne exécutée avec succès — email ouvert et lien cliqué à 100%. Confirme le besoin critique de sensibilisation des utilisateurs.

MFA/TOTP (Google Authenticator) : double authentification opérationnelle sur SSH. Même avec des identifiants volés, l'accès au serveur est protégé.

Analyse CVE : 22 vulnérabilités critiques identifiées par Wazuh, analysées et classées par système. Plan de remédiation défini avec priorisation CVSS

Suricata IDS : opérationnel avec les règles ET Open. Passage en mode IPS recommandé après la phase de tuning (3 mois).

Segmentation réseau (OPNsense) : isolation VLAN validée, règles de filtrage restrictives, principe du moindre privilège appliqué.

Active Directory : score Purple Knight 94/100 (Grade B), Tiering Model déployé, comptes nettoyés, GPO durcies.

Domaine	Avant audit	Après audit	Gain
Authentification	Faible (7 car., pas de complexité)	Fort (12 car., ANSSI)	MFA + ANSSI
Comptes admin	6 membres Admins du domaine	1 seul (Administrateur)	Moindre privilège
Segmentation réseau	Trop permissive	Restrictive (Deny All)	Zero Trust
Sécurité DMZ	Non durcie	SSH durci + UFW + fail2ban	Lynis 66/100
Détection d'incidents	Inexistante	Opérationnelle	Wazuh + Suricata + Purple Knight
Pare-feu	Règles basiques	OPNsense + IPS	Filtrage fin
Sensibilisation	Aucune	Programme actif	Formation + Phishing
Veille cyber	Aucune	Structurée	CERT-FR + IOC

9. Conclusion

Cet audit de cybersécurité Blue Team a permis de transformer la posture de sécurité du Bordeaux Football Club d'un état critique à un niveau de protection opérationnel et conforme aux bonnes pratiques.

- **Identification et remédiation des vulnérabilités critiques** : politique de mots de passe ANSSI, déploiement du MFA, suppression des comptes génériques et des privilèges excessifs.
- **Architecture Zero Trust** : micro-segmentation, principe du moindre privilège, règles de pare-feu restrictives, Tiering Model AD.
- **Sécurisation de la DMZ** : durcissement SSH, fail2ban, UFW, chiffrement TLS, score Lynis 66/100.
- **Capacité de détection et de réponse** : Wazuh (SIEM) avec 4071 alertes corrélées, Suricata (IDS/IPS), OPNsense (pare-feu).
- **Cadre organisationnel** : procédures de réponse aux incidents, sensibilisation, veille cybersécurité.

L'infrastructure du BFC dispose désormais d'une capacité de prévention, de détection et de réponse aux incidents. La tentative de fraude au président qui avait failli coûter 42 millions d'euros ne pourrait plus aboutir grâce au MFA, à la sensibilisation et à la détection par Wazuh.

Recommandations pour la suite :

- **Gouvernance et PRA** : L'infrastructure technique est désormais résiliente et supervisée.
 - La prochaine étape stratégique pour le BFC est la formalisation d'un Plan de Reprise d'Activité (PRA).
 - Ce document devra recenser les procédures métiers en mode dégradé (comment vendre des billets si les serveurs sont coupés).
 - Ce PRA devra obligatoirement faire l'objet d'un test grandeur nature (simulation de crash) au moins une fois par an.
- Réaliser un audit de pénétration (Red Team) dans les 6 prochains mois
- Continuer les campagnes de phishing simulées
- Planifier des exercices de crise cyber annuels
- Envisager un SOC externalisé pour une supervision 24/7

Annexes

Annexe A : Glossaire

Terme	Définition
MFA	Multi-Factor Authentication - Authentification a plusieurs facteurs
SIEM	Security Information and Event Management
IDS / IPS	Intrusion Détection / Prevention System
DMZ	Zone démilitarisée, segment réseau isole pour les services exposes
VLAN	Virtual Local Area Network - Reseau local virtuel
GPO	Group Policy Object - Strategie de groupe dans Active Directory
PSSI	Politique de Sécurité du Système d'Information
Zero Trust	Modèle de sécurité : Ne jamais faire confiance, toujours vérifier
IOC	Indicator of Compromise - Indicateur de compromission
FIM	File Integrity Monitoring - Surveillance de l'intégrité des fichiers
CVE	Common Vulnerabilities and Exposures
SCA	Security Configuration Assessment
TOTP	Time-based One-Time Password
BEC	Business Email Compromise

Annexe B : Environnement de lab (VMware)

VM	OS	RAM	Disque	Role
SRV-AD-01	Windows Server 2022	4 Go	60 Go	AD DS, DNS, DHCP
SRV-DMZ-01	Ubuntu Server 22.04	4 Go	80 Go	Apache, SSH, fail2ban
FW-OPNSENSE	OPNsense 26.1	2 Go	20 Go	Pare-feu, Suricata
PC-AUDIT	Kali Linux 2024	2 Go	40 Go	Audit, tests
SRV-WAZUH	Ubuntu Desktop 24.04	4 Go	80 Go	Wazuh All-in-One (SIEM)

Annexe C : Références

- ANSSI - Guide d'hygiène informatique (42 mesures)

- ANSSI - Recommandations relatives à l'authentification multi facteur et aux mots de passe
- NIST SP 800-207 - Zero Trust Architecture
- NIST SP 800-61 Rev. 2 - Computer Security Incident Handling Guide
- Documentation Wazuh : <https://documentation.wazuh.com>
- Documentation Suricata : <https://docs.suricata.io>
- Documentation OPNsense : <https://docs.opnsense.org>
- MITRE ATT&CK : <https://attack.mitre.org>

Annexe D : Analyse détaillée des CVE critiques

Les CVE critiques identifiées ont été analysées et classées par système. Les mesures correctives sont détaillées ci-dessous.

CVE sur SRV-DMZ-01 (Ubuntu 24.04 / OpenSSH / Apache)

CVE-2024-6387 (regreSSHion) : vulnérabilité d'exécution de code à distance dans OpenSSH (CVSS 8.1). Correction : mise à jour vers OpenSSH 9.8+ et restriction du port SSH (2222) via UFW et OPNsense.

CVE-2024-0567 : validation incorrecte des certificats GnuTLS (CVSS 7.5). Correction : mise à jour du paquet.

CVE-2023-44487 : attaque par déni de service HTTP/2 Rapid Reset sur Apache (CVSS 7.5). Correction : mise à jour d'Apache et limitation des streams.

CVE sur SRV-AD-01 (Windows Server 2022)

CVE-2024-49112 : exécution de code à distance via LDAP (CVSS 9.8). Correction : application du correctif Microsoft KB5043080.

CVE-2024-38124 : élévation de privilèges via Netlogon (CVSS 9.0). Correction : patch cumulatif et renforcement des GPO.

CVE-2024-43451 : divulgation du hash NTLMv2 (CVSS 6.5). Correction : désactivation de NTLMv1 et correctif appliqué.

CVE sur FW-OPNSENSE (Suricata / RADIUS)

CVE-2023-49793 : contournement de règles IDS via fragmentation (CVSS 7.5). Correction : mise à jour de Suricata.

CVE-2024-3596 : attaque man-in-the-middle sur RADIUS (CVSS 9.0). Correction : passage à RADIUS over TLS.

Recommandation : mettre en place une procédure de veille CVE mensuelle et appliquer les correctifs sous 30 jours pour les CVE critiques (CVSS $\geq$ 7.0).

--- Fin du rapport ---